



Siempresoft EIRL

PROCEDIMIENTO PARA AUDITORÍA INTERNA

Versión:	0.9
Fecha de la versión:	02/12/2025
Creado por:	Ana Karim Salazar
Aprobado por:	Milton Guevara
Nivel de confidencialidad:	Restringida

Historial de modificaciones

Fecha	Versión	Creado por	Descripción de la modificación
14-08-2019	0.1	Ana Karim Salazar	Versión inicial del documento
13-11-2020	0.2	Ana Karim Salazar	5. Validez y gestión de documentos , se retira: Al evaluar la efectividad y adecuación de este documento, es necesario tener en cuenta los siguientes criterios:
29-04-2021	0.3	Ana Karim Salazar	Cambio en la palabra “empleados” por “colaboradores”; “Asistente de Seguridad de la información” por “Oficial de Seguridad de la información”. En el punto 3.3.Designación de auditores internos , de: Se recomienda que los auditores internos realicen un curso para auditores internos según la norma ISO/IEC 27001. A: Se recomienda que los auditores reciban capacitaciones de Auditoría en la norma ISO/IEC 27001. En 4. Gestión de registros guardados en base a este documento: Programa anual de auditoría interna De: Gerente General. a: Oficial de seguridad de la
18-10-2022	0.4	Ana Karim Salazar	Cambios detallados en el Repositorio de documentos online de Siempresoft / 02 – Área de seguridad de la información / Anexos / Anexo N°13.pdf
24-01-2023	0.5	Ana Karim Salazar	Modificación en el primer párrafo del punto 1. Objetivo, alcance y usuarios de: El objetivo de este procedimiento es definir ... por: El objetivo de este procedimiento es describir las actividades relacionadas con las auditorías internas realizadas por personas que no pertenecen a la organización, en adelante considerados auditores externos. Retiro de los puntos: - todo el 3.3. Designación de auditores internos - primera línea en 3.4. Realización de auditorías internas "Las personas responsables de las auditorías internas individuales están identificadas en el Programa anual de auditoría interna", "Lista de apoyo de auditoría interna; ver Apéndice 3" - último registro en 4. Gestión de registros guardados en base a este documento "Lista de apoyo de auditoría interna". - Formato: Apéndice 2 Informe de auditoría interna y apéndice 3 Lista de apoyo auditoría interna.

05-10-2023	0.6	Ana Karim Salazar	Modificación en 3.1. Objetivo de la auditoría interna: de: "El objetivo de la auditoría interna es determinar si los procedimientos, ... " a: "El objetivo de la auditoría interna es verificar que el SGSI: • Sea conforme y cumpla con los requisitos internos de la Siempresoft y los requisitos de la NTP ISO/EC 27001:2022. • Esté eficazmente implementado y mantenido." Incorporación de 4. Identificación de riesgos en el programa de auditoría. Apéndice 1: Programa anual de auditoría interna Nombre del proceso dentro del alcance: de: ERP con Facturación electrónica y Validación de comprobantes OSE a: FACTURACIÓN ELECTRÓNICA PSE Y VALIDACIÓN DE COMPROBANTES OSE Eliminación del área Infraestructura tecnológica Incorporación de ítems: Nuevo criterio de la auditoría - Políticas, procedimientos y estándares correspondientes al SGSI. - El auditor debe tener las competencias suficientes para alcanzar los objetivos de la auditoría. - El auditor debe brindar algunas recomendaciones de mejora.
23-11-2024	0.7	Ana Karim Salazar	Cambio en la fecha de vigencia
06-12-2024	0.8	Ana Karim Salazar	Incorporación: * Nuevo apartado 3.5. Realización de auditorías de Ethical Hacking * Registro en el apartado 5. Gestión de registros guardados en base a este documento Informe de hacking ético
02-12-2025	0.9	Ana Karim Salazar	Cambio en la fecha de vigencia

Tabla de contenido

1. OBJETIVO, ALCANCE Y USUARIOS	5
2. DOCUMENTOS DE REFERENCIA.....	5
3. AUDITORÍA INTERNA	5
3.1. OBJETIVO DE LA AUDITORÍA INTERNA	5
3.2. PLANIFICACIÓN DE LA AUDITORÍA INTERNA.....	5
3.3. SELECCIÓN DE AUDITORES EXTERNOS	5
3.4. REALIZACIÓN DE AUDITORÍAS INTERNAS.....	6
4. GESTIÓN DE REGISTROS GUARDADOS EN BASE A ESTE DOCUMENTO	7
5. VALIDEZ Y GESTIÓN DE DOCUMENTOS	7
6. APÉNDICES.....	8

1. Objetivo, alcance y usuarios

El objetivo de este procedimiento es describir las actividades relacionadas con las auditorías internas realizadas por personas que no pertenecen a la organización, en adelante considerados auditores externos.

Este procedimiento se aplica a todas las actividades realizadas dentro del Sistema de Gestión de Seguridad de la Información (SGSI).

Los usuarios de este documento son: Gerencia General, Área de Seguridad de la Información y Auditores externos.

2. Documentos de referencia

- Norma ISO/IEC 27001, clausula 9.2
- Política de seguridad de la información
- Procedimiento para medidas correctivas y preventivas

3. Auditoría interna

3.1. Objetivo de la auditoría interna

El objetivo de la auditoría interna es verificar que el SGSI:

- Sea conforme y cumpla con los requisitos internos de la Siempresoft, requisitos de la NTP ISO/IEC 27001:2022 y control 8.8 del Anexo A.
- Esté eficazmente implementado y mantenido.

3.2. Planificación de la auditoría interna

El Gerente General aprueba el programa anual de auditorías internas, redactado como se detalla en el formulario del Apéndice 1.

Se deben realizar una o más auditorías internas en el transcurso de un año, asegurando una cobertura acumulativa de todo el alcance del SGSI. Las auditorías internas son planificadas en base a la evaluación de riesgos, como también por los resultados de auditorías anteriores. Generalmente son realizadas antes de la revisión por parte de la gerencia.

El Programa anual de auditoría interna debe incluir la siguiente información sobre cada auditoría interna individual:

- Momento de la auditoría (especificando fechas o el mes en el que está planificada la auditoría).
- Objetivo de la auditoría
- Alcance de la auditoría (departamentos, procesos, puntos de la norma, etc.).
- Criterio de auditoría (normas, disposiciones legales, documentación interna, obligaciones contractuales y/o normas corporativas).
- Quién realizará la auditoría (si será más de un auditor, especificar quién será el auditor líder).
- Hallazgos

Se debe llevar un registro de las auditorías realizadas en el Programa anual de auditoría interna.

3.3. Selección de auditores externos

Los auditores externos son personas naturales o personas jurídicas con RUC a los cuales se les debe emitir facturas por sus servicios, por lo tanto, también son considerados proveedores.

El Gerente General es el encargado de seleccionar a los auditores externos.

Un auditor externo sólo puede ser una persona externa a la organización. Los criterios para la selección de los auditores externos son:

- Experiencia en la norma ISO/IEC 27001: 2022.
- Conocimiento en leyes y regulaciones sobre seguridad de la información.
- Que esté familiarizado sobre técnicas de auditoría en sistemas de gestión.
- Que sepa cómo funcionan las tecnologías de la información y de la comunicación como para estar familiarizado con el objetivo de los sistemas individuales y también con los impactos sobre procedimientos de seguridad y/o continuidad del negocio.
- Debe contar con acreditación.

Se debe seleccionar a los auditores externos de tal forma de garantizar objetividad e imparcialidad; es decir, de evitar el conflicto de intereses.

3.4. Realización de auditorías internas

Si una auditoría es realizada por un equipo de varios auditores, la persona responsable de la auditoría es aquella que está indicada como Líder de equipo de auditoría.

Durante la realización de una auditoría interna se deben tener en cuenta los siguientes puntos:

- El criterio establecido en el Programa anual de auditoría interna.
- Los resultados de auditorías internas o externas anteriores.
- Los resultados de la evaluación de riesgos, de la implementación de controles, del análisis de impacto en los negocios, etc.

Se deben documentar los siguientes elementos como resultado de la auditoría interna:

- Informe de auditoría interna, debe ser enviado al Gerente General y Oficial de Seguridad de la información.
- Las posibles medidas correctivas deben ser documentadas en el Formulario para acciones correctivas, de acuerdo con lo establecido en el Procedimiento para medidas correctivas.

3.5. Realización de auditorías de Ethical Hacking

La auditoría debe ser realizada por una empresa especialista en ciberseguridad, para recopilar la información queda permitida la explotación de las vulnerabilidades desde el punto de vista del ejercicio ético en el entorno autorizado por la organización.

Se debe documentar el resultado y enviar al Gerente General y Oficial de Seguridad de la información:

- Informe ejecutivo como mínimo debe contener:
 - Alcance
 - Roles y responsabilidades
 - Duración
 - Objetivo
 - Metodología

- Tipos de prueba
- Recursos (componente tecnológico)
- Herramientas utilizadas
- Listado de vulnerabilidades identificadas
- Conclusiones
- Recomendaciones para mitigar las vulnerabilidades.
- Informe técnico de las herramientas empleadas
- Las posibles medidas correctivas deben ser documentadas en el Formulario para acciones correctivas, de acuerdo con lo establecido en el Procedimiento para medidas correctivas.

4. Identificación de riesgos en el programa de auditoría

- Dificultad para establecer objetivos del programa de auditoría.
- Que el auditor asignado no cuente con las competencias necesarias para llevar a cabo la auditoría de manera efectiva.
- Inefectiva comunicación del programa de auditoría.
- Fallas o inconvenientes con las evidencias de auditoría.
- Indisponibilidad de algún miembro de los roles auditados.

5. Gestión de registros guardados en base a este documento

Nombre del registro	Ubicación de archivo	Persona responsable del archivo	Controles para la protección del registro	Tiempo de retención
Programa anual de auditoría interna (en formato electrónico)	Repositorio de documentos online de Siempresoft / 02 - Área de Seguridad de la Información / Restringida / Documentos vigentes	Oficial de Seguridad de la Información	Solamente el Oficial de Seguridad de la información y el auditor interno pueden ingresar datos y modificaciones al Programa anual de auditoría interna.	Los programas son almacenados por el plazo de 3 años.
Informe de auditoría interna (en formato electrónico)	Repositorio de documentos online de Siempresoft / 02 - Área de Seguridad de la Información / Registros	Auditor interno	Los informes son almacenados en versiones de sólo lectura.	Los informes son guardados por un período de 3 años.
Informe de hacking ético	Repositorio de documentos online de Siempresoft / 02 - Área de Seguridad de la Información / Registros	Auditor hacking	Los informes son almacenados en versiones de sólo lectura.	Los informes son guardados por un período de 3 años.

Solamente el Gerente General puede otorgar a otros colaboradores el derecho de acceso al Programa anual de auditoría interna, al Informe de auditoría interna y a la Lista de apoyo de auditoría interna.

6. Validez y gestión de documentos

Este documento es válido hasta el 02/12/2026.

El propietario de este documento es el Oficial de Seguridad de la Información, que debe verificar, y si es necesario actualizar, el documento por lo menos una vez al año.

7. Apéndices

- Apéndice 1: Programa anual de auditoría interna